Análisis de Vulnerabilidad en Samba

Explorando la Amenaza CVE-2007-2447 en Entornos de Laboratorio

Informe SOC – Vulnerabilidad Samba CVE-2007-2447

1. Contexto del análisis

Durante un laboratorio de **Vulnerability Scanning** realizado en la plataforma whoami-labs.com, se ejecutó un escaneo activo con Nmap sobre la dirección IP 172.17.0.2. El objetivo era identificar servicios expuestos y evaluar posibles vulnerabilidades en un entorno controlado.

2. Hallazgo principal

Se detectó un servicio **Samba 3.0.20-Debian** expuesto en los puertos 139 (NetBIOS) y 445 (SMB). Esta versión se encuentra dentro del rango afectado por la vulnerabilidad CVE-2007-2447, que permite ejecución remota de comandos (RCE) mediante una configuración insegura del parámetro username map script.

3. Evaluación de criticidad

Según la base de datos de NIST/NVD, la vulnerabilidad presenta una puntuación **CVSS v2.0: 6.0 - Medium**. No dispone de vector CVSS v3 por tratarse de una vulnerabilidad antigua. Factores que elevan el riesgo real:

- **Exposición del servicio** en puertos críticos (139/445)
- **Posibilidad de RCE sin autenticación**
- **Software obsoleto** sin mitigaciones aplicadas
- **SMBv1 activo** y acceso guest habilitado

4. Evidencia técnica

- **Herramienta**: Nmap 7.99
- **Comando ejecutado**: sudo nmap -sV -sC -O -p- --open 172.17.0.2 -oN resultado_vuln.txt
- **Servicio detectado**: Samba 3.0.20-Debian
- **Puertos abiertos**: 139/tcp, 445/tcp

- **Coincidencia confirmada**: versiones vulnerables 3.0.0 - 3.0.25rc3

5. Impacto potencial

La explotación exitosa de esta vulnerabilidad permitiría a un atacante ejecutar comandos arbitrarios en el sistema afectado, comprometiendo la integridad y disponibilidad del servidor. En entornos corporativos, podría facilitar movimientos laterales y escaladas de privilegios.

6. Recomendaciones

- **Actualizar Samba** a una versión superior a 3.0.25rc3.
- **Deshabilitar SMBv1** y acceso guest.
- **Implementar segmentación de red** para limitar exposición.
- **Realizar auditorías periódicas** de servicios y versiones.

7. Conclusión

Aunque el CVSS base indica severidad media, el contexto operativo eleva el riesgo a alto. Este caso demuestra la importancia de evaluar vulnerabilidades considerando exposición, antigüedad del software y configuración del entorno.

Analista: Ruth Esther Pérez Reyes
Fecha: 19 Abril 2026
Tipo de informe: SOC - Vulnerability Report